

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-SOC2-03

SOC 2 Evidence Collection Guide

What Auditors Look For and How to Build an Evidence Library That Passes
TSEC Compliance Insights | SOC 2 Series

Document ID:	GUIDE-SOC2-03
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

TSEC Compliance Insights | TSEC Risk & Cyber Advisory LLC | www.tsecgrc.com | info@tsecgrc.com

1. Introduction: Evidence Is What Auditors Actually Test

Policies describe how controls should work. Evidence demonstrates that they actually did. This distinction is at the heart of SOC 2 Type II examinations: auditors test operating effectiveness by reviewing real evidence that controls ran consistently throughout the examination period. Organizations that fail to build evidence collection habits before the examination period begins often find themselves scrambling to reconstruct six months of activity — an exercise that is both stressful and often unconvincing to auditors.

This Evidence Collection Guide provides a systematic inventory of the evidence types most commonly requested by SOC 2 auditors, organized by Trust Services Criteria category. Use it as a checklist to build and maintain your evidence library throughout the examination period.

2. How Auditors Select Evidence

For each control, the auditor requests a population — the complete set of instances of the control operating during the examination period. From the population, auditors select a sample using a risk-based or statistical approach, and test each item in the sample. For a 12-month Type II period, a typical access provisioning control might have a population of 150 new access grants, from which the auditor selects 25 samples and reviews each for documented approval prior to access being provided.

Evidence quality matters as much as availability. Clean, organized exports with clear timestamps and user identifiers are easier for auditors to test — and faster for your team to produce — than unstructured screenshots or raw log files.

3. Control Environment (CC1) Evidence

Control Activity	Typical Evidence
Board or management oversight of the security program	Board meeting minutes referencing security topics; Steering Committee minutes; CISO/security reports provided to leadership
Code of Conduct / policy acknowledgment	Signed acknowledgment records for all personnel; LMS completion records for policy training
Performance evaluations referencing security responsibilities	HR system records or manager attestations confirming security responsibilities are evaluated
Organizational chart showing security function reporting structure	Current organizational chart; CISO job description

4. Risk Assessment (CC3) Evidence

Control Activity	Typical Evidence
Annual risk assessment	Risk Assessment report or Risk Register dated within the examination period; management sign-off
Risk treatment decisions	Risk Register entries showing treatment selections, owners, and dates
Changes in risk profile communicated to management	Steering Committee minutes; risk escalation emails; updated Risk Register entries

5. Logical and Physical Access (CC6) Evidence

Control Activity	Typical Evidence
Access provisioning requires documented approval	Ticketing system exports showing access request, approver, date of approval, and date access was granted
MFA enforced for remote access and production systems	Identity provider configuration screenshots; MFA enforcement policy settings; sample MFA enrollment records
Periodic access reviews conducted	Access review records signed or attested by system owners, with dates and evidence of any access removed
Access revoked upon termination	HR offboarding records; IT offboarding checklist completions; user account deactivation logs
Privileged access reviewed quarterly	Privileged access review records with dates; list of privileged accounts before and after review
Physical access to data center/server room restricted	Badge access logs; visitor log entries; photos of physical security controls

6. System Operations (CC7) Evidence

Control Activity	Typical Evidence
Vulnerability scanning performed	Scan reports with dates; vulnerability management system exports showing identified vulnerabilities and remediation status
Penetration testing conducted annually	Penetration test report; scope definition; letter of engagement; management response to findings
Security events monitored and alerts investigated	SIEM/monitoring platform alert logs; triage records; escalation tickets for investigated alerts
Incidents documented and responded to	Incident log or ticketing system showing incidents, severity, response actions, and resolution dates
Log retention configured	Logging platform configuration screenshots showing retention settings

7. Change Management (CC8) Evidence

Control Activity	Typical Evidence
Code changes require peer review before merging	Pull request records from source control platform (GitHub, GitLab, etc.) showing reviewer approval before merge
Deployments to production require approval	CI/CD pipeline configuration showing approval gates; deployment tickets with approver documented
Testing performed before production deployment	Test results in CI/CD pipeline; staging environment test run records; automated test suite pass reports
Emergency changes documented retrospectively	Emergency change tickets with retrospective approval and incident reference

8. Risk Mitigation / Vendor Management (CC9) Evidence

Control Activity	Typical Evidence
Vendor risk assessments conducted	Vendor Inventory with tier assignments; due diligence questionnaire responses; vendor SOC 2 reports or ISO 27001 certificates on file
Vendor SOC 2 reports reviewed annually	Dated review notes or email correspondence confirming receipt and review of vendor audit reports
Subservice organization controls mapped	CUEC tracking document; management's response to CUECs from subservice organization SOC 2 reports

9. Security Awareness Training Evidence

Control Activity	Typical Evidence
Annual security awareness training for all personnel	LMS training completion report showing all in-scope personnel, module name, completion date, and score
New hire training completed at onboarding	Onboarding checklist or LMS records showing training completed within defined period of hire date
Phishing simulations conducted	Phishing simulation platform report showing dates, targets, click rates, and training assigned to those who clicked

10. Evidence Collection Best Practices

- Build a shared evidence folder organized by TSC criterion at the start of the examination period — don't wait until audit fieldwork to start collecting
- Use system exports (timestamped, system-generated) rather than manual screenshots where possible — they are harder to dispute
- For population-based controls (access reviews, change approvals), keep a running log throughout the year rather than trying to reconstruct it at audit time
- Label evidence clearly: the control it relates to, the date range it covers, and who produced it
- Date-stamp everything: auditors need to confirm evidence falls within the examination period
- Don't over-produce: auditors request samples, not entire populations — producing clean, organized samples is more valuable than providing thousands of raw records

11. Availability Category Evidence

Control Activity	Typical Evidence
Availability commitments defined and communicated	Service agreements or Terms of Service documenting uptime commitments; status page or SLA documentation
System capacity monitored against thresholds	Monitoring dashboard screenshots or exports showing capacity metrics; alerting configuration showing thresholds
Redundancy and failover implemented	Architecture diagrams; cloud provider configuration exports showing multi-AZ or multi-region deployment; failover test records
Backup restoration tested	Backup restoration test records with dates, systems tested, RPO met, and any issues identified

Business continuity plan tested annually	BCP/DRP test records; tabletop exercise notes; after-action report
--	--

12. Confidentiality Category Evidence

Control Activity	Typical Evidence
Data classification policy documented and communicated	Data Classification Policy; training records confirming personnel are aware of classification requirements
Customer data encrypted at rest and in transit	Encryption configuration screenshots; TLS/SSL configuration showing cipher suites and protocol versions; data store encryption settings
Confidential data subject to access controls	Access control lists or RBAC configuration for systems containing Confidential data; access review records
Data retention and disposal per policy	Deletion records or logs; media destruction certificates; retention schedule documentation

13. Building an Evidence Request Response Process

During audit fieldwork, auditors submit Information Request Lists (IRLs) — a structured list of evidence items needed for each control being tested. Your ability to respond to IRLs quickly and accurately materially affects the audit timeline and the auditor's confidence in your organization's control environment.

Best practices for managing the evidence request process:

- Designate a single point of contact (typically someone on the compliance or engineering team) to manage the IRL process — receiving requests, routing them to the right person, and confirming completeness before submission
- Set internal SLAs for evidence responses (e.g., 2 business days per request) and track compliance with them during fieldwork
- Never submit raw system logs as evidence without context — include a brief explanation of what the evidence is, the date range it covers, and how it demonstrates the control
- If evidence doesn't exist for a specific sample (e.g., a missing access review for a particular system in a particular quarter), don't wait for the auditor to discover this — proactively disclose and explain
- Maintain a 'lessons learned' log after each audit, capturing which evidence items were hardest to produce, so you can build collection habits for the next examination period

14. Sample Evidence Request — Access Provisioning Control

To illustrate what an evidence request looks like in practice, the following table shows a typical IRL entry for an access provisioning control and the evidence an organization would need to produce.

IRL Field	Content
Control Reference	CC6.1, CC6.2
Control Description	Access to production systems is provisioned only upon documented approval from the system owner prior to access being granted.

Population	All new access grants to production systems during the examination period (assume 87 access grants)
Sample Size	25 access grants
Evidence Requested	For each of 25 selected access grants: (1) the access request (ticket, email, or form); (2) evidence of system owner approval; (3) evidence that approval preceded access provisioning (timestamps must support this); (4) evidence of MFA enrollment where applicable
Ideal Evidence Format	Export from ticketing system showing request, approver, approval date, and action taken; or email thread showing request and approval; plus identity provider log showing account creation date
Common Issues	Approval timestamp after access provisioning timestamp (suggests access was given first, approval obtained after); approver is the same person as the requester (segregation of duties concern); no evidence of approval — only the access itself